

TLP:AMBER — RESTRICTED DISTRIBUTION

THREAT INTELLIGENCE EXECUTIVE SUMMARY

TeamPCP GitHub Internal Repository Breach

Date: 20 May 2026

Classification: TLP:AMBER

Severity: **CRITICAL**

Target: GitHub (Microsoft subsidiary)

Threat Actor: TeamPCP (aka DeadCatx3, PCPcat, UNC6780)

Status: Active Investigation / Ongoing Campaign

⚠ AI-ASSISTED INTELLIGENCE SUMMARY — ANALYST REVIEW REQUIRED BEFORE OPERATIONAL USE ⚠

1. Executive Summary

On 20 May 2026, the financially-motivated threat actor TeamPCP (also tracked as DeadCatx3, PCPcat, ShellForce, CipherForce, and UNC6780) claimed to have exfiltrated approximately 4,000 internal GitHub repositories and listed the alleged dataset for sale on underground cybercrime forums for a minimum asking price of \$50,000. GitHub confirmed the breach, with its ongoing investigation finding the attacker's claims directionally consistent with approximately 3,800 internal repositories having been exfiltrated. GitHub stated there is currently no evidence of impact to customer data stored outside its internal repositories.

The intrusion was made possible after a GitHub employee installed a trojanised Visual Studio Code extension — a technique that is central to TeamPCP's Mini Shai-Hulud self-replicating supply chain worm, active throughout 2026. This is not an isolated incident: it is the latest and most high-profile step in a sustained, escalating supply chain campaign in which each compromise feeds credentials harvested from the previous victim into the next attack.

The GitHub breach represents a significant escalation in TeamPCP's targeting profile. Compromise of GitHub's internal source code carries potential downstream risks for the entire global software supply chain, as internal tooling, CI/CD secrets, signing keys, and infrastructure automation could be leveraged for follow-on attacks against organisations that rely on GitHub-hosted software.

OVERALL RISK RATING: CRITICAL

Confirmed breach of a Tier-1 software platform. Exfiltrated data may contain secrets, signing keys, internal tooling, and CI/CD configurations with potential downstream impact across the global developer ecosystem. Active investigation ongoing as of 20 May 2026.

2. Threat Actor Profile

2.1 Identity & Aliases

Attribute	Detail
Primary Name	TeamPCP
Aliases	DeadCatx3, PCPcat, ShellForce, CipherForce, UNC6780, Black Witch / PCP
Classification	Financially-motivated cybercriminal group / supply chain threat actor
First Observed	Late 2025
Origin (assessed)	Unknown — operating with Russian-language ransomware partner (Vect RaaS)
Primary Motivation	Financial — credential theft, data resale, dual ransomware deployment
Victims (known)	60,000+ servers; 1,000+ SaaS environments; GitHub, Aqua Security (Trivy), Checkmarx (KICS), LiteLLM, Telnyx, Palo Alto Networks, 66+ npm packages, European Commission AWS environment

Data Volume	~500,000 credentials stolen; ~300+ GB data exfiltrated (cumulative campaign)
--------------------	--

2.2 Capabilities & Tools

- Mini Shai-Hulud — Self-replicating supply chain worm targeting npm, PyPI, and VS Code extensions. Harvests cloud and developer credentials, then uses stolen access to publish further poisoned packages, creating a self-sustaining propagation loop.
- CipherForce Ransomware — TeamPCP's proprietary ransomware programme deployed against victims post-credential theft.
- Vect RaaS Partnership — Formal affiliate arrangement with the Vect ransomware group (Russian-speaking, 80–88% profit share), enabling dual monetisation of compromised access.
- FRP (Fast Reverse Proxy) — Used to establish reverse proxy tunnels for persistent C2 access.
- Sliver C2 Framework — Open-source adversary simulation framework providing mTLS, WireGuard, HTTP(S), and DNS C2 channels.
- FIRESCALE Mechanism — Backup C2 resolution technique using GitHub public commit messages to embed base64-encoded C2 addresses, enabling resilient command-and-control even when primary domains are blocked.
- pull_request_target Abuse ("Pwn Requests") — Exploitation of misconfigured GitHub Actions workflows to exfiltrate CI/CD secrets from repositories.

3. Incident Timeline — GitHub Breach

Date (UTC)	Phase	Event
Late 2025	Initial Activity	TeamPCP emerges targeting exposed Docker APIs, Kubernetes clusters, Redis, and Ray dashboards. Estimates of 60,000+ servers compromised.
Mar 2026	Supply Chain Escalation	Cascading supply chain campaign: Aqua Trivy, Checkmarx KICS, LiteLLM, Telnyx, Palo Alto Networks, and 66+ npm packages poisoned. European Commission AWS environment breached.
May 2026 (early)	Worm Expansion	Mini Shai-Hulud worm compromises TanStack, Mistral AI, guardrails-ai packages. Okta publishes supply chain defence guidance on 19 May.
~May 2026	Initial Access — GitHub	GitHub employee installs trojanised VS Code extension. Credential stealer executes, harvesting developer secrets, CI/CD tokens, and GitHub internal access credentials.
~May 2026	Exfiltration	Attackers access GitHub internal repositories using stolen credentials. Approximately 3,800 private repositories exfiltrated.
~May 2026	Monetisation Attempt	TeamPCP posts alleged GitHub source code for sale on BreachForums: minimum offer \$50,000. Threatens free leak if no buyer is found.
19 May 2026	durabletask Compromise	Microsoft's durabletask PyPI package (versions 1.4.1–1.4.3, ~417,000 downloads/month) poisoned with credential-stealing dropper fetching second-stage from check.git-service[.]com.
20 May 2026	Public Disclosure	GitHub confirms investigation. Malicious VS Code extension removed. Affected endpoint isolated. Credential rotation initiated. GitHub states no evidence of customer data impact at time of statement.

4. Attack Chain Analysis

4.1 GitHub Breach Kill Chain

- Stage 1 — Initial Access: GitHub employee installs a poisoned VS Code extension. The extension contains a dropper that executes immediately on installation, targeting the developer workstation.
 - MITRE ATT&CK: T1195.001 — Compromise Software Dependencies and Development Tools
 - MITRE ATT&CK: T1566.002 — Spearphishing Link (social distribution of trojanised extension)
- Stage 2 — Credential Theft: The dropper deploys a full-featured infostealer (Linux-targeted) capable of harvesting AWS, GCP, Azure, GitHub PATs, SSH keys, Docker credentials, password manager vaults (1Password, Bitwarden), HashiCorp Vault KV secrets, VPN configs, and shell history.
 - MITRE ATT&CK: T1552.001 — Credentials in Files

- MITRE ATT&CK: T1555 — Credentials from Password Stores
- MITRE ATT&CK: T1528 — Steal Application Access Token
- Stage 3 — Internal Repository Access: Stolen GitHub credentials used to authenticate to GitHub's internal infrastructure and exfiltrate approximately 3,800 private repositories.
 - MITRE ATT&CK: T1078.004 — Valid Accounts: Cloud Accounts
 - MITRE ATT&CK: T1213 — Data from Information Repositories
- Stage 4 — Exfiltration: Repository contents exfiltrated to attacker-controlled infrastructure. C2 communications use the FIRESALE mechanism (GitHub public commit messages as a dead-drop resolver) as a backup channel.
 - MITRE ATT&CK: T1567.001 — Exfiltration to Code Repository
 - MITRE ATT&CK: T1102 — Web Service (FIRESALE dead-drop resolver)
- Stage 5 — Monetisation: Data listed for sale on BreachForums. Parallel threat of free leak used as leverage. CipherForce/Vect ransomware deployed opportunistically against other victims in the same campaign.
 - MITRE ATT&CK: T1657 — Financial Theft

4.2 Mini Shai-Hulud Worm — Self-Propagation Loop

The worm's propagation mechanism is particularly notable from a threat modelling perspective. Once deployed on an infected host, it:

- Enumerates SSM-managed EC2 instances (AWS) and propagates to up to 5 additional instances per profile via SendCommand and the AWS-RunShellScript document.
- Propagates through Kubernetes clusters via kubectl exec.
- Uses stolen PyPI/npm tokens from infected environments to publish new poisoned package versions, feeding the next wave of infections.
- Embeds backup C2 addresses in GitHub public commit messages in the format "FIRESALE <base64_url>.<base64_signature>" — a resilient dead-drop resolver technique that is difficult to block without broad allowlisting.
- Contains a geofencing trigger: on systems with Israeli or Iranian locale settings, there is a 1-in-6 probability of playing audio and executing `rm -rf /*`, suggesting a possible destructive secondary objective.

5. MITRE ATT&CK Technique Summary

Technique ID	Name	Context
T1195.001	Supply Chain Compromise: Software Deps	Poisoned VS Code extension, PyPI, and npm packages
T1059.006	Python Execution	Second-stage payload (rope.pyz) and credential stealer written in Python
T1078.004	Valid Accounts: Cloud Accounts	Stolen GitHub PATs, AWS/GCP/Azure credentials used for lateral access
T1528	Steal Application Access Token	PATs, CI/CD tokens, PyPI/npm publishing tokens harvested
T1552.001	Credentials in Files	SSH keys, Docker configs, shell history, VPN configs read from disk
T1555	Credentials from Password Stores	1Password and Bitwarden vaults unlocked and dumped
T1102	Web Service	FIRESCALE: GitHub public commits used as dead-drop C2 resolver
T1213	Data from Information Repositories	GitHub internal repositories exfiltrated
T1567	Exfiltration Over Web Service	Data exfiltrated to attacker-controlled domains
T1496	Resource Hijacking	Compromised servers used for cryptomining and proxy infrastructure
T1486	Data Encrypted for Impact (Ransomware)	CipherForce / Vect RaaS deployed against victims post-credential theft
T1053.005	Scheduled Task/Job	Persistence mechanism on compromised systems

6. Known Indicators of Compromise

Note: All IOCs should be validated against your environment before actioning. Confidence ratings reflect available corroboration at time of writing.

6.1 Network Indicators

Indicator	Type	Confidence	Notes
check.git-service[.]com	C2 Domain	HIGH	Primary C2 — serves rope.pyz second-stage payload
t.m-kosche[.]com	C2 Domain	HIGH	Fallback C2 for Mini Shai-Hulud propagation
FIRESCALE pattern in GitHub commits: "FIRESCALE"	Dead-drop Resolver	HIGH	Search public GitHub commit messages for

<b64_url>.<b64_sig>"			this pattern
----------------------	--	--	--------------

6.2 File / Package Indicators

Indicator	Type	Confidence	Notes
durabletask 1.4.1, 1.4.2, 1.4.3	PyPI Package	HIGH	Confirmed malicious. Remove immediately. ~417k downloads/month.
rope.pyz	Dropper Payload	HIGH	Second-stage payload fetched from check.git-service[.]com
28KB Python stealer (infostealer payload)	Malware	HIGH	Linux-only. Targets cloud creds, password managers, SSH, Docker, VPN, shell history.
Trojanised VS Code extension (name not yet publicly disclosed)	Malicious Extension	MED	Delivered to GitHub employee. Extension name/ID under investigation.

6.3 Behavioural Indicators (EDR / SIEM)

- VS Code extension process spawning unexpected child processes (python, curl, bash) — monitor for code.exe / code spawning network-connected child processes.
- Python process reading ~/.ssh/, ~/.docker/config.json, ~/.aws/credentials, ~/.config/gcloud outside of normal developer tooling hours.
- AWS SSM SendCommand calls with the AWS-RunShellScript document to multiple EC2 instances in rapid succession from a single source.
- kubectl exec commands issued to multiple pods from a single source in short succession.
- Outbound HTTP/S connections to non-CDN, non-known-good domains from CI/CD runner hosts.
- GitHub commit messages matching the regex: FIRESCALE\s+[A-Za-z0-9+/]+\+=*\.[A-Za-z0-9+/]+\+=*

7. Impact Assessment

7.1 Confirmed Impact

- ~3,800 GitHub internal repositories exfiltrated, confirmed by GitHub's ongoing investigation.
- Potential exposure of GitHub internal source code, build tooling, CI/CD pipeline configurations, internal service authentication, and infrastructure automation.
- Microsoft's durabletask PyPI package (versions 1.4.1–1.4.3) compromised and actively serving malicious payloads to any environment that imported the package.
- Credential exfiltration at scale across the broader supply chain campaign: approximately 500,000 credentials stolen and over 300 GB of data exfiltrated to date.

7.2 Unconfirmed / Potential Impact (Under Investigation)

- GitHub internal secrets (API keys, signing certificates, OAuth app secrets) that could enable future supply chain attacks if not rotated.
- Internal tooling and deployment scripts that could reveal attack surface or facilitate targeted exploitation of GitHub infrastructure.
- Downstream risk: any organisation using GitHub-hosted Actions, packages, or CI/CD integrations should assess whether their dependencies could be affected by follow-on attacks using exfiltrated GitHub internals.

7.3 GitHub's Current Assessment (20 May 2026)

Scope	Status
GitHub internal repositories (~3,800)	CONFIRMED EXFILTRATED
Customer enterprise/org repositories	No evidence of impact (investigation ongoing)
Customer personal repositories	No evidence of impact (investigation ongoing)
GitHub.com platform availability	Not impacted

8. Recommended Actions

8.1 Immediate Actions (Within 24 Hours)

- Audit installed VS Code extensions across all developer workstations. Remove any extension not present in an approved allowlist. Treat any machine that installed a non-approved extension recently as potentially compromised.
- Remove and quarantine durabletask PyPI versions 1.4.1, 1.4.2, and 1.4.3 from all environments. Treat any host or CI/CD pipeline that ran code importing these versions as fully compromised.
- Rotate all developer credentials on potentially affected machines: GitHub PATs, cloud provider API keys (AWS, GCP, Azure), SSH keys, Docker credentials, and CI/CD secrets.
- Block network access to check.git-service[.]com and t.m-kosche[.]com at perimeter/proxy and deploy detection rules for DNS queries to these domains.

- Search GitHub public commit history in your organisation's repositories for the FIRESALE pattern.

8.2 Short-Term Actions (Within 7 Days)

- Enforce VS Code extension allowlisting via policy (VSCode workspace settings, GPO, or MDM). Only permit extensions from a curated, reviewed list.
- Audit GitHub Actions workflows for use of the `pull_request_target` trigger. Remove or constrain it where not operationally required. Implement SHA pinning for all GitHub Actions dependencies.
- Review CI/CD secret scoping: ensure secrets follow the principle of least privilege, are short-lived where possible, and are scoped to specific repositories and workflows.
- Implement phishing-resistant MFA (passkeys or FIDO2 hardware keys) for all accounts with GitHub repository write access, package publishing rights, or cloud infrastructure access.
- Deploy SBOM generation for all software build pipelines to enable rapid identification of affected packages in future supply chain incidents.
- Add the FIRESALE regex to SIEM/SOAR GitHub audit log monitoring.

8.3 Medium-Term Actions (Within 30 Days)

- Implement an n-1 dependency strategy (or a minimum 24-hour release age hold) for third-party package ingestion in production pipelines.
- Deploy a Software Composition Analysis (SCA) tool (e.g., Snyk, Socket.dev) integrated into the CI/CD pipeline to flag suspicious or newly-published package versions.
- Conduct a purple team exercise against the TeamPCP supply chain kill chain — specifically testing detection of: trojanised VS Code extension execution, credential harvesting from developer workstations, and FIRESALE C2 resolution.
- Review trust relationships with upstream open-source packages: Aqua Trivy, Checkmarx KICS, LiteLLM, and any other packages previously identified as compromised in the TeamPCP campaign.
- Ensure incident response playbooks cover supply chain scenarios including: poisoned dependency discovery, mass credential rotation procedures, and package registry token revocation.

9. Detection Guidance

9.1 Sigma Rule — VS Code Extension Spawning Credential Stealer

```
title: VS Code Extension Spawning Credential Harvesting Process
id: a4f8c2d1-9e3b-4a7f-b5c8-2d1e6f3a8b9c
status: experimental
description: Detects VS Code spawning processes associated with credential theft
(TeamPCP Mini Shai-Hulud)
tags:
  - attack.credential_access
  - attack.t1528 - attack.t1552.001 - attack.t1195.001
logsource:
  category: process_creation
  product: linux
detection:
  selection_parent:
    ParentImage|endswith:
      - '/code'
      - '/code-server'
  selection_suspicious_child:
    Image|endswith:
      - '/python3' - '/python' - '/curl' - '/wget'
    CommandLine|contains:
      - '.aws/credentials' - '.ssh/' - '.docker/config'
      - 'rope.pyz' - 'git-service.com'
  condition: selection_parent and selection_suspicious_child
falsepositives:
  - Legitimate dev tooling that invokes Python from VS Code
level: high
```

9.2 KQL — GitHub Audit Log: FIRESALE Dead-Drop Resolver

```
// Hunt: FIRESALE C2 resolver pattern in GitHub commit messages
// Requires GitHub audit log ingestion into Sentinel/Defender
GitHubAuditLog
| where TimeGenerated > ago(30d)
| where Action == 'git.push'
| where CommitMessage matches regex @"FIRESALE\s+[A-Za-z0-9+/]+\.*\.[A-Za-z0-9+/]+\.*"
| project TimeGenerated, Actor, Repository, CommitMessage, IPAddress
| order by TimeGenerated desc
```

9.3 KQL — AWS CloudTrail: Rapid SSM Propagation (Mini Shai-Hulud)

```
// Hunt: Multiple SSM SendCommand calls to different EC2 instances from same caller
AWSCloudTrail
| where TimeGenerated > ago(1d)
| where EventSource == 'ssm.amazonaws.com'
| where EventName == 'SendCommand'
| where RequestParameters has 'AWS-RunShellScript'
| summarize TargetCount=count(), Targets=make_set(RequestParameters)
  by UserIdentityArn, bin(TimeGenerated, 5m)
| where TargetCount >= 3
| order by TargetCount desc
```

10. Sources & References

- The Hacker News (20 May 2026) — GitHub Investigating TeamPCP Claimed Breach of ~4,000 Internal Repositories
 - <https://thehackernews.com/2026/05/github-investigating-teampcp-claimed.html>
- Help Net Security (20 May 2026) — TeamPCP breached GitHub's internal codebase via poisoned VS Code extension
 - <https://www.helpnetsecurity.com/2026/05/20/github-breached-teampcp/>
- Okta Threat Intelligence (19 May 2026) — Defending against Team PCP software supply chain attacks
 - https://www.okta.com/en-gb/blog/threat-intelligence/defending_against_team_pcp_software_supply_chain_attacks/
- BleepingComputer (20 May 2026) — GitHub investigates internal repositories breach claimed by TeamPCP
 - <https://www.bleepingcomputer.com/news/security/github-investigates-internal-repositories-breach-claimed-by-teampcp/>
- SOCRadar (2026) — TeamPCP GitHub Breach: Internal GitHub Repositories Allegedly Accessed
 - <https://socradar.io/blog/teampcp-github-breach-internal-github-repository/>
- CybersecurityNews (2026) — GitHub Source Code Breach - TeamPCP Claims Access to Internal Source Code
 - <https://cybersecuritynews.com/github-source-code-breach/>
- GBHackers (2026) — GitHub Source Code Reportedly Compromised, TeamPCP Claims Breach
 - <https://gbhackers.com/github-source-code-reportedly-compromised/>
- Flare.io — Threat Alert: TeamPCP, An Emerging Force in the Cloud Native and Ransomware Landscape
 - <https://flare.io/learn/resources/blog/teampcp-cloud-native-ransomware>
- Palo Alto Unit 42 — Weaponizing the Protectors: TeamPCP's Multi-Stage Supply Chain Attack on Security Infrastructure
 - <https://unit42.paloaltonetworks.com/teampcp-supply-chain-attacks/>
- Wiz Cloud Threat Landscape — TeamPCP Actor Profile
 - <https://threats.wiz.io/all-actors/teampcp>
- Aikido Security — GitHub Breached via VS Code Extension | Developer Supply Chain Attack 2026
 - <https://www.aikido.dev/blog/github-breached-vs-code-extension>

 AI-ASSISTED REPORT — VALIDATE ALL FINDINGS BEFORE OPERATIONAL USE

This document was generated with AI assistance on 20 May 2026. Intelligence is based on open-source reporting and should be corroborated against primary sources and your own telemetry before use in an operational context.